Asset Register - Inventory

Asset ID	Asset Name	Type	Owner	Location	Classification	Business Process
A001	Source Code Repository	Information Asset	Natalia Romanoff	GitHub (Cloud)	Confidential	SaaS Development
A002	AWS EC2 Production	Technical Asset	Maria Hill	AWS Cloud (US-East)	Restricted	Hosting SaaS Application
A003	CI/CD Pipeline	Technical Asset	Natalia Romanoff	GitHub Actions	Confidential	Code Deployment
A004	Developer Laptop	Physical Asset	James Rhodes	Austin HQ	Internal Use Only	Development
A005	Data	Information Asset	Lolade Oluwole	AWS S3 / Databases	Confidential	SaaS Application Functionality

Asset Register - Security

Asset ID	Asset Name	Confidentiality	Integrity	Availability	Threats	Vulnerabilities
A001	Source Code Repository	High	High	Medium	Code theft, insider threat	Weak permissions
A002	AWS EC2 Production	High	High	High	Misconfiguration, DoS	Open ports, default settings
A003	CI/CD Pipeline	Medium	High	High	Pipeline compromise, secrets leak	Hardcoded secrets, poor logging
A004	Developer Laptop	Medium	Medium	Medium	Malware, data leakage, theft	No endpoint protection, lack of awareness
A005	Data	High	High	Medium	Data corruption, unauthorised access	Misconfigured access policies, weak encryption

Risk Assesment - Risk Details

Risk ID	Asset ID	Asset Name	Risk Description	Threats	Vulnerabilities
R001	A001	Source Code Repository	Unauthorised access to source code	Code theft, insider threat	Weak permissions
R002	A002	AWS EC2 Production	Service disruption due to DoS attack	DoS, misconfiguration	Open ports, default settings
R003	A003	CI/CD Pipeline	Compromise of deployment pipeline	Pipeline compromise, secrets leak	Hardcoded secrets, poor logging
R004	A004	Developer Laptop	Malware infection from phishing email	Malware, phishing, theft	No endpoint protection, lack of awareness
R005	A005	Data	Unauthorised access or corruption of business-critical data	Data corruption, unauthorised access	Misconfigured access policies, weak encryption

Risk Assesment - Evaluation and Treatment

Risk ID	Asset Name	Likelihood (1–5)	Impact (1–5)	Risk Score	Risk Level	Treatment Option
R001	Source Code Repository	4	5	20	High	Mitigate
R002	AWS EC2 Production	3	5	15	High	Mitigate
R003	CI/CD Pipeline	3	4	12	Medium	Mitigate
R004	Developer Laptop	4	3	12	Medium	Mitigate
R005	Data	4	5	20	High	Mitigate

Risk Assesment - Controls and Follow-up

Risk ID	Asset Name	Proposed Controls	Residual Risk Score	Residual Risk Level	Risk Owner	Status
R001	Source Code Repository					
R002	AWS EC2 Production					
R003	CI/CD Pipeline					
R004	Developer Laptop					
R005	Data					

SOA

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
5	Organisational Controls	5.1	Policies for information security	Information security policy and topic-specific policies shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.	Yes	Applicable to establish consistent security direction for the SaaS platform and supporting activities. Policy/document basis: Information Security Policy (Purpose, Leadership Commitment, Continual Improvement) and topic-specific policies (Policy Review). Further evidence/coverage: Approval, publication and acknowledgement records were not supplied.
		5.2	Information security roles and responsibilities	Information security roles and responsibilities shall be defined and allocated according to the organisation needs.	Yes	Applicable because ISMS activities require assigned ownership and reporting responsibilities. Policy/document basis: ISMS Roles & Responsibilities (Key Roles and Responsibilities; Authority Delegation).
		5.3	Segregation of duties	Conflicting duties and conflicting areas of responsibility shall be segregated.	Yes	Applicable to separate conflicting duties in code deployment, access approval and restoration. Policy/document basis: Access Control Policy (Segregation of Duties Implementation), with ISMS Roles & Responsibilities.
		5.4	Management responsibilities	Management shall require all personnel to apply information security in accordance with the established information security policy, topic-specific policies and procedures of the organisation.	Yes	Applicable to require managers and personnel to follow the ISMS policies and assigned responsibilities. Policy/document basis: Information Security Policy (Responsibilities; Leadership Commitment) and Training & Awareness Policy (Accountability).

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		5.5	Contact with authorities	The organisation shall establish and maintain contact with relevant authorities.	No	Screenshot exclusion: The application is assumed not to store confidential data. Review required: This does not establish that authority contacts are unnecessary. The asset register classifies source code and data as Confidential. Incident Management Policy requires escalation and notifications; define relevant authority contacts.
		5.6	Contact with special interest groups	The organisation shall establish and maintain contact with special interest groups or other specialist security forums and professional associations.	No	Screenshot exclusion: The application is assumed not to store confidential data and threat intelligence is excluded. Review required: Confidential assets are recorded, and Risk Assessment Process identifies industry threat intelligence as an input. Assess the need for relevant security groups; no contact register was supplied.
		5.7	Threat intelligence	Information relating to information security threats shall be collected and analysed to produce threat intelligence.	No	Screenshot exclusion: The application is assumed not to store confidential data and threat intelligence is excluded. Review required: Conflicts with the asset classifications and Risk Assessment Process (Threats and Vulnerabilities), which lists threat intelligence sources. Reassess inclusion for SaaS and cloud threats.
		5.8	Information security in project management	Information security shall be integrated into project management.	No	Screenshot exclusion: No project management activities take place. Review required: The scope includes SaaS development and deployment. Secure Development Policy (SDLC) requires security requirements and threat modelling for releases. Confirm whether exclusion is defensible for those projects.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		5.9	Inventory of information and other associated assets	An inventory of information and other associated assets, including owners, shall be developed and maintained	Yes	Applicable to identify the assets supporting SaaS development and operation and assign ownership. Policy/document basis: Asset Management & Data Classification Policy (Asset Inventory; Asset Ownership) and Asset Register worksheet.
		5.10	Acceptable use of information and other associated assets	Rules for the acceptable use and procedures for handling information and other associated assets shall be identified, documented and implemented.	Yes	Applicable to govern authorised use and handling of company devices, systems and information. Policy/document basis: Acceptable Use Policy (Acceptable Use Requirements; Use of Company Devices) and Asset Management & Data Classification Policy (Acceptable Use of Assets).
		5.11	Return of assets	Personnel and other interested parties as appropriate shall return all the organisation's assets in their possession upon change or termination of their employment, contract or agreement.	Yes	Applicable to recover company assets when personnel or contractors leave. Policy/document basis: Acceptable Use Policy (Use of Company Devices) and Asset Management & Data Classification Policy (Asset Lifecycle Management). Further evidence/coverage: Document the asset return checklist and evidence for role changes and departures.
		5.12	Classification of information	Information shall be classified according to the information security needs of the organisation based on confidentiality, integrity, availability and relevant interested party requirements.	Yes	Applicable because assets have different confidentiality, integrity and availability requirements. Policy/document basis: Asset Management & Data Classification Policy (Asset Classification) and Asset Register worksheet.
		5.13	Labelling of information	An appropriate set of procedures for information labelling shall be developed and implemented in accordance with the information classification scheme adopted by the organisation.	Yes	Applicable to make the assigned information classification visible throughout its lifecycle. Policy/document basis: Asset Management & Data Classification Policy (Information Labelling).

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		5.14	Information transfer	Information transfer rules, procedures, or agreements shall be in place for all types of transfer facilities within the organisation and between the organisation and other parties.	Yes	Applicable to protect information transferred through APIs, networks, email and third-party services. Policy/document basis: Cryptography Policy (Data in Transit; Key Distribution), Acceptable Use Policy (Acceptable Use Requirements) and Supplier and Vendor Management Policy (Contractual Obligations). Further evidence/coverage: Define approved transfer channels, recipients and transfer agreements for each information class.
		5.15	Access control	Rules to control physical and logical access to information and other associated assets shall be established and implemented based on business and information security requirements.	Yes	Applicable to restrict access to SaaS systems, source code and cloud resources according to business need. Policy/document basis: Access Control Policy (Access Control Principles; Access to Sensitive Data).
		5.16	Identity management	The full life cycle of identities shall be managed.	Yes	Applicable to manage user identities from registration to removal. Policy/document basis: Access Control Policy (User Access Management; Access Review and Monitoring). Further evidence/coverage: Remove duplicated registration sections and specify identity lifecycle checks.
		5.17	Authentication information	Allocation and management of authentication information shall be controlled by a management process, including advising personnel on appropriate handling of authentication information.	Yes	Applicable to protect passwords, credentials and authentication secrets. Policy/document basis: Access Control Policy (User Responsibilities; Authentication Requirements) and Cryptography Policy (Authentication). Further evidence/coverage: Document secure credential issuance and reset procedures.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		5.18	Access rights	Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed in accordance with the organisation's topic-specific policy on and rules for access control.	Yes	Applicable to approve, review, change and revoke access rights as roles change. Policy/document basis: Access Control Policy (User Access Management; Access Review and Monitoring; Roles and Responsibilities).
		5.19	Information security in supplier relationships	Processes and procedures shall be defined and implemented to manage the information security risks associated with the use of supplier's products or services.	Yes	Applicable because AWS, GitHub and other suppliers support in-scope services. Policy/document basis: Supplier and Vendor Management Policy (Identification & Classification; Risk Assessment; Roles and Responsibilities).
		5.20	Addressing information security within supplier agreements	Relevant information security requirements shall be established and agreed with each supplier based on the type of supplier relationship.	Yes	Applicable to agree security obligations with suppliers before access or service delivery. Policy/document basis: Supplier and Vendor Management Policy (Contractual Obligations), including confidentiality, breach notification, audit rights and service levels.
		5.21	Managing information security in the information and communication technology (ICT) supply chain	Processes and procedures shall be defined and implemented to manage the information security risks associated with the ICT products and services supply chain.	No	Screenshot exclusion: Products in the supply chain are excluded. Review required: The platform depends on AWS, GitHub and third-party software. Supplier and Vendor Management Policy covers supplier risk and Secure Development Policy (SDLC) covers dependencies. Assess ICT supply-chain exposure before retaining this exclusion.
		5.22	Monitoring, review and change management of supplier services	The organisation shall regularly monitor, review, evaluate and manage change in supplier information security practices and service delivery.	No	Screenshot exclusion: No changes are expected to AWS service delivery or security practices. Review required: Conflicts with Supplier and Vendor Management Policy (Monitoring and Review), which requires annual critical supplier reviews. Absence of an anticipated change does not address ongoing supplier oversight.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		5.23	Information security for use of cloud services	Processes for acquisition, use, management and exit from cloud services shall be established in accordance with the organisation's information security requirements.	Yes	Applicable because the SaaS platform and development services operate in the cloud. Policy/document basis: Supplier and Vendor Management Policy (Supplier Lifecycle Requirements; Offboarding and Exit Strategy), Access Control Policy (Authentication Requirements) and ISMS Scope document (AWS responsibilities).
		5.24	Information security incident management planning and preparation	The organisation shall plan and prepare for managing information security incidents by defining, establishing and communicating information security incident management processes, roles and responsibilities.	Yes	Applicable to prepare coordinated incident response for cloud, application and endpoint incidents. Policy/document basis: Incident Management Policy (Incident Response Process; Roles and Responsibilities; Testing and Continuous Improvement).
		5.25	Assessment and decision on information security events	The organisation shall assess information security events and decide if they are to be categorised as information security incidents.	Yes	Applicable to assess security events and decide incident severity and response. Policy/document basis: Incident Management Policy (Definitions; Assessment; Classification Guidelines) and Monitoring & Logging Policy (Integration with Incident Management).
		5.26	Response to information security incidents	Information security incidents shall be responded to in accordance with the documented procedures.	Yes	Applicable to contain, eradicate and recover from incidents affecting the SaaS platform. Policy/document basis: Incident Management Policy (Incident Response Process; Communication and Escalation).
		5.27	Learning from information security incidents	Knowledge gained from information security incidents shall be used to strengthen and improve the information security controls.	Yes	Applicable to use incident findings to improve controls and prevent recurrence. Policy/document basis: Incident Management Policy (Lessons Learned; Testing and Continuous Improvement).

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		5.28	Collection of evidence	The organisation shall establish and implement procedures for the identification, collection, acquisition and preservation of evidence related to information security events.	Yes	Applicable to preserve incident logs and other evidence for investigation. Policy/document basis: Incident Management Policy (Evidence Handling and Logging) and Monitoring & Logging Policy (Protection and Integrity). Further evidence/coverage: Define chain-of-custody and evidence acquisition procedures.
		5.29	Information security during disruption	The organisation shall plan how to maintain information security at an appropriate level during disruption.	Yes	Applicable to maintain information security during outages and other disruptions. Policy/document basis: Business Continuity & Disaster Recovery Policy (Business Continuity Planning; Communication During Disruption) and Incident Management Policy (Recovery). Further evidence/coverage: Specify security controls maintained during fallback operation.
		5.30	ICT readiness for business continuity	ICT readiness shall be planned, implemented, maintained and tested based on business continuity objectives and ICT continuity requirements.	Yes	Applicable to recover the SaaS platform and other critical services within defined RTO and RPO targets. Policy/document basis: Business Continuity & Disaster Recovery Policy (Critical Functions and Systems; Disaster Recovery Planning; Testing and Maintenance).
		5.31	Legal, statutory, regulatory and contractual requirements	Legal, statutory, regulatory and contractual requirements relevant to information security and the organisation's approach to meet these requirements shall be identified, documented and kept up to date.	Yes	Applicable to identify and maintain relevant information security obligations. Policy/document basis: Information Security Policy (Compliance with Requirements), Supplier and Vendor Management Policy (Contractual Obligations) and Data Retention & Disposal Policy (Data Retention Policy). Further evidence/coverage: Validate applicable obligations in a requirements register; the policy assumption of no legal/regulatory requirements is not substantiated.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		5.32	Intellectual property rights	The organisation shall implement appropriate procedures to protect intellectual property rights.	No	Screenshot exclusion: No intellectual property rights are in scope. Review required: Source code is an in-scope asset and Secure Development Policy (SDLC) addresses third-party libraries. Acceptable Use Policy prohibits pirated content. Review software ownership and licence obligations before excluding.
		5.33	Protection of records	Records shall be protected from loss, destruction, falsification, unauthorised access and unauthorised release.	No	Screenshot exclusion: The application does not store records. Review required: Conflicts with Data Retention & Disposal Policy (logs, deployment, incident and contract records) and Monitoring & Logging Policy (Retention and Storage). Reassess protection of these in-scope records.
		5.34	Privacy and protection of personal identifiable information (PII)	The organisation shall identify and meet the requirements regarding the preservation of privacy and protection of PII according to applicable laws and regulations and contractual requirements	No	Screenshot exclusion: The application is assumed not to store personally identifiable information. Review required: The scope of assessment must also consider employee records, customer support data and logs listed in Data Retention & Disposal Policy. Validate data flows and privacy requirements before excluding.
		5.35	Independent review of information security	The organisation's approach to managing information security and its implementation including people, processes and technologies shall be reviewed independently at planned intervals, or when significant changes occur.	Yes	Applicable to obtain independent assurance over the ISMS and its controls. Policy/document basis: Information Security Policy (Commitment to Continual Improvement), ISMS Roles & Responsibilities (GRC Analyst audit duties) and ISMS Objectives (annual internal audit). Further evidence/coverage: Define reviewer independence, scope and reporting; avoid self-review of controls designed or operated by the reviewer.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		5.36	Compliance with policies, rules and standards for information security	Compliance with the organisation's information security policy, topic-specific policies, rules and standards shall be regularly reviewed.	Yes	Applicable to assess compliance with security policies and correct deviations. Policy/document basis: Information Security Policy (Responsibilities; Continual Improvement), ISMS Roles & Responsibilities (corrective actions) and Monitoring & Logging Policy (Compliance and Auditing).
		5.37	Documented operating procedures	Operating procedures for information processing facilities shall be documented and made available to personnel who need them.	No	Screenshot exclusion: The project is assumed not to involve operating procedures or operational activities. Review required: Conflicts with the scope of SaaS operations and the incident, logging, access and recovery procedures in the supplied policies. Reassess and identify required operating instructions.
6	People Controls	6.1	Screening	Background verification checks on all candidates to become personnel shall be carried out prior to joining the organisation and on an ongoing basis taking into consideration applicable laws, regulations and ethics and be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.	Yes	Applicable to assess personnel suitability before access to sensitive systems and assets. Policy/document basis: Related documents: ISMS Roles & Responsibilities and Access Control Policy (User Access Management). Further evidence/coverage: No screening policy or procedure was supplied. Define lawful, proportionate screening and retain supporting records.
		6.2	Terms and conditions of employment	The employment contractual agreements shall state the personnel's and the organisation's responsibilities for information security.	Yes	Applicable to establish personnel security responsibilities in employment or engagement terms. Policy/document basis: Information Security Policy (Responsibilities), ISMS Roles & Responsibilities (All Employees and Contractors) and Acceptable Use Policy (Acknowledgement). Further evidence/coverage: Employment/contract templates with security terms were not supplied.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		6.3	Information security awareness, education and training	Personnel of the organisation and relevant interested parties shall receive appropriate information security awareness, education and training and regular updates of the organisation's information security policy, topic-specific policies and procedures, as relevant for their job function.	Yes	Applicable to ensure staff understand security responsibilities and receive role-based training. Policy/document basis: Training & Awareness Policy (Induction Training; Role-Based Training; Training Records) and Secure Development Policy (SDLC) (Secure Coding Training).
		6.4	Disciplinary process	A disciplinary process shall be formalised and communicated to take actions against personnel and other relevant interested parties who have committed an information security policy violation	Yes	Applicable to address breaches of security policy consistently. Policy/document basis: Acceptable Use Policy (Disciplinary Action), Access Control Policy (Enforcement) and Training & Awareness Policy (Accountability). Further evidence/coverage: Formal disciplinary steps, authorities and fair process need documentation.
		6.5	Responsibilities after termination or change of employment	Information security responsibilities and duties that remain valid after termination or change of employment shall be defined, enforced and communicated to relevant personnel and other interested parties.	Yes	Applicable to manage security duties and access when employment ends or roles change. Policy/document basis: Access Control Policy (User Access Management) and Acceptable Use Policy (Use of Company Devices). Further evidence/coverage: Document continuing confidentiality obligations after termination and how they are communicated.
		6.6	Confidentiality or non-disclosure agreements	Confidentiality or non-disclosure agreements reflecting the organisation’s needs for the protection of information shall be identified, documented, regularly reviewed and signed by personnel and other relevant interested parties.	Yes	Applicable to protect confidential source code, business data and supplier information. Policy/document basis: Access Control Policy (Remote Access and Third Parties; Access to Sensitive Data) and Supplier and Vendor Management Policy (Contractual Obligations). Further evidence/coverage: NDA templates, executed agreements and review records were not supplied.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		6.7	Remote working	Security measures shall be implemented when personnel are working remotely to protect information accessed, processed or stored outside the organisation's premises.	Yes	Applicable to secure remote access to AWS, development tools and company information. Policy/document basis: Access Control Policy (Remote Access and Third Parties; MFA) and Acceptable Use Policy (Use of Company Devices; Use of Cloud Services). Further evidence/coverage: Document remote workspace and device protection requirements in more detail.
		6.8	Information security event reporting	The organisation shall provide a mechanism for personnel to report observed or suspected information security events through appropriate channels in a timely manner.	Yes	Applicable to enable staff and third parties to report suspected events promptly. Policy/document basis: Incident Management Policy (Incident Reporting), Acceptable Use Policy (Acceptable Use Requirements) and Training & Awareness Policy (Induction Training).
7	Physical Controls	7.1	Physical security perimeters	Security perimeters shall be defined and used to protect areas that contain information and other associated assets.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Confirm boundaries for offices and home workspaces as well as AWS facilities. Related basis: ISMS Scope document and Supplier and Vendor Management Policy.
		7.2	Physical entry	Secure areas shall be protected by appropriate entry controls and access points.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Assess access to workspaces holding developer laptops and information. AWS facility controls are supplier responsibilities, not evidence that all physical entry risks are excluded.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		7.3	Securing offices, rooms and facilities	Physical security for offices, rooms and facilities shall be designed and implemented.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: The asset register includes a developer laptop at an office location. Review protection of that workspace alongside AWS assurance evidence.
		7.4	Physical security monitoring	Premises shall be continuously monitored for unauthorised physical access.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Assess monitoring needs for company premises separately from AWS data centres; no physical monitoring procedure was supplied.
		7.5	Protecting against physical and environmental threats	Protection against physical and environmental threats, such as natural disasters and other intentional or unintentional physical threats to infrastructure shall be designed and implemented.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Business Continuity & Disaster Recovery Policy addresses disasters, power and internet disruption. Assess personnel, endpoints and workspace exposure beyond AWS facilities.
		7.6	Working in secure areas	Security measures for working in secure areas shall be designed and implemented.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Confirm whether restricted work areas exist and what protection is needed. Access Control Policy does not define secure-area working procedures.
		7.7	Clear desk and clear screen	Clear desk rules for papers and removable storage media and clear screen rules for information processing facilities shall be defined and appropriately enforced.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Acceptable Use Policy requires workstation locking. Endpoint and remote work exposure remains even when the application is cloud-hosted; assess clear desk/screen requirements.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		7.8	Equipment siting and protection	Equipment shall be sited securely and protected.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: The developer laptop is an in-scope asset. Acceptable Use Policy requires device security; assess equipment siting and protection.
		7.9	Security of assets off-premises	Off-site assets shall be protected.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Access Control Policy permits remote access and Acceptable Use Policy addresses device security. Assess off-premises laptop use before excluding.
		7.10	Storage media	Storage media shall be managed through their life cycle of acquisition, use, transportation and disposal in accordance with the organisation's classification scheme and handling requirements.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Asset Management & Data Classification Policy explicitly covers media handling, encryption, movement and wiping. The screenshot exclusion conflicts with that policy.
		7.11	Supporting utilities	Information processing facilities shall be protected from power failures and other disruptions caused by failures in supporting utilities.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Business Continuity & Disaster Recovery Policy includes HQ power/internet disruption. Assess supporting utilities at company locations and obtain AWS assurance evidence.
		7.12	Cabling security	Cables carrying power, data or supporting information services shall be protected from interception, interference or damage.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Confirm company workspace/network cabling as well as AWS responsibilities. No cabling procedure or site assessment was supplied.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		7.13	Equipment maintenance	Equipment shall be maintained correctly to ensure availability, integrity and confidentiality of information	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Developer laptops are in the asset register. Define maintenance arrangements; AWS hosting alone does not address endpoint maintenance.
		7.14	Secure disposal or re-use of equipment	Items of equipment containing storage media shall be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.	No	Screenshot exclusion: The application is hosted on AWS; physical facilities are treated as out of scope. Review required: Data Retention & Disposal Policy and Asset Management & Data Classification Policy require secure disposal. Assess laptop/media disposal before retaining the exclusion.
8	Technological Controls	8.1	User end point devices	Information stored on, processed by or accessible via user end point devices shall be protected.	Yes	Applicable to protect the developer laptop and other endpoints used for SaaS access and development. Policy/document basis: Acceptable Use Policy (Use of Company Devices), Asset Management & Data Classification Policy (Asset Inventory) and Access Control Policy (Authentication Requirements). Further evidence/coverage: Endpoint configuration, encryption and protection evidence must be recorded.
		8.2	Privileged access rights	The allocation and use of privileged access rights shall be restricted and managed.	Yes	Applicable to restrict privileged AWS, source code and production access. Policy/document basis: Access Control Policy (Least Privilege; Access Review and Monitoring; MFA).
		8.3	Information access restriction	Access to information and other associated assets shall be restricted in accordance with the established topic-specific policy on access control.	Yes	Applicable to limit access to confidential and restricted information according to job role. Policy/document basis: Access Control Policy (Need to Know; RBAC; Access to Sensitive Data) and Asset Management & Data Classification Policy (Asset Classification).

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		8.4	Access to source code	Read and write access to source code, development tools and software libraries shall be appropriately managed.	Yes	Applicable to protect the source code repository and development tools against unauthorised access. Policy/document basis: Access Control Policy (Access to Sensitive Data) and Secure Development Policy (SDLC) (DevOps and CI/CD Pipeline Controls).
		8.5	Secure authentication	Secure authentication technologies and procedures shall be implemented based on information access restrictions and the topic-specific policy on access control.	Yes	Applicable to authenticate users of cloud, remote access and administrative services securely. Policy/document basis: Access Control Policy (Authentication Requirements; MFA) and Cryptography Policy (Authentication).
		8.6	Capacity management	The use of resources shall be monitored and adjusted in line with current and expected capacity requirements.	Yes	Applicable to maintain SaaS availability as processing and storage demand changes. Policy/document basis: Related documents: ISMS Objectives (availability target), Monitoring & Logging Policy (application health monitoring) and Business Continuity & Disaster Recovery Policy (critical services). Further evidence/coverage: No capacity management procedure defines demand forecasts, thresholds or scaling actions.
		8.7	Protection against malware	Protection against malware shall be implemented and supported by appropriate user awareness.	Yes	Applicable to address malware exposure recorded for developer laptops and company systems. Policy/document basis: Acceptable Use Policy (prohibition on disabling antivirus), Training & Awareness Policy (awareness) and Incident Management Policy (response process). Further evidence/coverage: Document malware prevention configuration, update schedules and effectiveness checks.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		8.8	Management of technical vulnerabilities	Information about technical vulnerabilities of information systems in use shall be obtained, the organisation's exposure to such vulnerabilities shall be evaluated and appropriate measures shall be taken.	Yes	Applicable to identify and remediate technical vulnerabilities in the SaaS platform and dependencies. Policy/document basis: Secure Development Policy (SDLC) (Vulnerability Management; Management of Open-Source Software), ISMS Roles & Responsibilities (Information Security Analyst) and ISMS Objectives (remediation target).
		8.9	Configuration management	Configurations, including security configurations, of hardware, software, services and networks shall be established, documented, implemented, monitored and reviewed.	Yes	Applicable to reduce cloud and deployment misconfiguration risks. Policy/document basis: Secure Development Policy (SDLC) (infrastructure-as-code review), ISMS Roles & Responsibilities (IT Infrastructure Engineer) and Monitoring & Logging Policy (System changes). Further evidence/coverage: Define approved configuration baselines, change records and configuration review schedules.
		8.10	Information deletion	Information stored in information systems, devices or in any other storage media shall be deleted when no longer required.	Yes	Applicable to remove information when retention ends or assets are decommissioned. Policy/document basis: Data Retention & Disposal Policy (Data Disposal & Deletion) and Asset Management & Data Classification Policy (Asset Lifecycle Management).
		8.11	Data masking	Data masking shall be used in accordance with the organisation's topic-specific policy on access control and other related topic-specific policies, and business requirements, taking applicable legislation into consideration.	No	Screenshot exclusion: Data masking is treated as out of scope. Review required: No data-based rationale is provided. Secure Development Policy (SDLC) prohibits production data in test environments. Confirm whether testing/support uses sensitive data and whether masking is needed.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		8.12	Data leakage prevention	Data leakage prevention measures shall be applied to systems, networks and any other devices that process, store or transmit sensitive information.	No	Screenshot exclusion: The application is assumed not to store confidential data. Review required: Conflicts with confidential source code/data in the asset register. Acceptable Use Policy prohibits unauthorised copying and Access Control Policy restricts sensitive data. Assess data leakage prevention needs.
		8.13	Information backup	Backup copies of information, software and systems shall be maintained and regularly tested in accordance with the agreed topic-specific policy on backup.	Yes	Applicable to recover information and systems after loss, corruption or ransomware. Policy/document basis: Business Continuity & Disaster Recovery Policy (Disaster Recovery Planning: encrypted backups and monthly tests) and Data Retention & Disposal Policy (Backup Data).
		8.14	Redundancy of information processing facilities	Information processing facilities shall be implemented with redundancy sufficient to meet availability requirements.	Yes	Applicable to support SaaS availability during infrastructure failures. Policy/document basis: Related documents: Business Continuity & Disaster Recovery Policy (cloud outage scenarios; RTO/RPO) and ISMS Objectives (99.9% availability target). Further evidence/coverage: A redundancy architecture and failover implementation records were not supplied.
		8.15	Logging	Logs that record activities, exceptions, faults and other relevant events shall be produced, stored, protected and analysed.	Yes	Applicable to retain security-relevant events for investigation and accountability. Policy/document basis: Monitoring & Logging Policy (Logging Requirements; Retention and Storage; Protection and Integrity).

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		8.16	Monitoring activities	Networks, systems and applications shall be monitored for anomalous behaviour and appropriate actions taken to evaluate potential information security incidents.	Yes	Applicable to detect abnormal activity in SaaS, cloud and deployment systems. Policy/document basis: Monitoring & Logging Policy (Review and Monitoring; Real-Time Monitoring; Integration with Incident Management).
		8.17	Clock synchronisation	The clocks of information processing systems used by the organisation shall be synchronised to approved time sources.	Yes	Applicable to correlate timestamps across cloud, application and incident logs. Policy/document basis: Related policy: Monitoring & Logging Policy (Logging Requirements; investigations). Further evidence/coverage: The policy does not specify clock synchronisation or approved time sources. Its A.8.17 real-time monitoring heading is not evidence of this control.
		8.18	Use of privileged utility programs	The use of utility programs that can be capable of overriding system and application controls shall be restricted and tightly controlled.	No	Screenshot exclusion: No privileged utility programs are in use. Review required: Confirm against actual AWS, endpoint and administration tooling. Access Control Policy limits privileges but no utility inventory was supplied to support exclusion.
		8.19	Installation of software on operational systems	Procedures and measures shall be implemented to securely manage software installation on operational systems	Yes	Applicable to control installation and deployment of software on operational systems. Policy/document basis: Acceptable Use Policy (prohibition on unauthorised software), Secure Development Policy (SDLC) (Deployment and Maintenance) and Access Control Policy (Segregation of Duties).

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		8.20	Networks security	Networks and network devices shall be secured, managed and controlled to protect information in systems and applications	Yes	Applicable to protect cloud and application networks from unauthorised access and disruption. Policy/document basis: ISMS Roles & Responsibilities (technical network controls), Access Control Policy (secure remote access) and Monitoring & Logging Policy (Network activity). Further evidence/coverage: Document network security configuration, ownership and rules; no dedicated network security standard was supplied.
		8.21	Security of network services	Security mechanisms, service levels and service requirements of network services shall be identified, implemented and monitored.	Yes	Applicable to specify and oversee security of network services supporting the SaaS platform. Policy/document basis: Supplier and Vendor Management Policy (Contractual Obligations; service level expectations) and Access Control Policy (Remote Access and Third Parties). Further evidence/coverage: Define network service security requirements and evidence of provider compliance.
		8.22	Segregation of networks	Groups of information services, users and information systems shall be segregated in the organisation’s networks.	Yes	Applicable to limit lateral movement and separate systems with different security requirements. Policy/document basis: Related policies: Access Control Policy (Least Privilege; RBAC) and ISMS Roles & Responsibilities (network control responsibilities). Further evidence/coverage: No explicit network segmentation design or procedure was supplied; logical access control alone does not demonstrate network segregation.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		8.23	Web filtering	Access to external websites shall be managed to reduce exposure to malicious content.	Yes	Applicable to reduce endpoint exposure to malicious websites and phishing. Policy/document basis: Acceptable Use Policy (Acceptable and Unacceptable Use) and Training & Awareness Policy (Induction Training). Further evidence/coverage: No web filtering rules, service configuration or exception process was supplied.
		8.24	Use of cryptography	Rules for the effective use of cryptography, including cryptographic key management, shall be defined and implemented.	Yes	Applicable to protect sensitive information in transit and at rest and manage cryptographic keys. Policy/document basis: Cryptography Policy (Cryptographic Use Cases; Key Management; Acceptable Cryptographic Standards).
		8.25	Secure development life cycle	Rules for the secure development of software and systems shall be established and applied.	Yes	Applicable to integrate security into the SaaS development lifecycle. Policy/document basis: Secure Development Policy (SDLC) (Design, Development, Testing, Deployment and Maintenance requirements).
		8.26	Application security requirements	Information security requirements shall be identified, specified and approved when developing or acquiring applications.	Yes	Applicable to define security requirements before developing or acquiring applications. Policy/document basis: Secure Development Policy (SDLC) (Design Phase; Product Owner responsibilities).
		8.27	Secure system architecture and engineering principles	Principles for engineering secure systems shall be established, documented, maintained and applied to any information system development activities.	Yes	Applicable to address security in application and infrastructure design. Policy/document basis: Secure Development Policy (SDLC) (Design Phase: threat modelling, security requirements and secure libraries; infrastructure-as-code review). Further evidence/coverage: Document detailed architecture/engineering principles and design review evidence.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		8.28	Secure coding	Secure coding principles shall be applied to software development	Yes	Applicable to prevent vulnerabilities introduced in SaaS source code. Policy/document basis: Secure Development Policy (SDLC) (Development Phase; Secure Coding Training; secrets handling and code reviews).
		8.29	Security testing in development and acceptance	Security testing processes shall be defined and implemented in the development life cycle.	Yes	Applicable to identify security defects before production releases. Policy/document basis: Secure Development Policy (SDLC) (Testing and QA: SAST, DAST and manual review) and ISMS Objectives (code review and penetration testing objectives).
		8.30	Outsourced development	The organisation shall direct, monitor and review the activities related to outsourced system development.	No	Screenshot exclusion: Development is performed in-house, with no planned outsourced development. Review required: Confirm all development arrangements remain in-house. Supplier and Vendor Management Policy includes development partners; reassess if such services are used.
		8.31	Separation of development, test and production environments	Development, testing and production environments shall be separated and secured.	Yes	Applicable to prevent development/testing activities from compromising production. Policy/document basis: Secure Development Policy (SDLC) (Testing and QA: non-production test data; Deployment and Maintenance) and Access Control Policy (deployment approvals). Further evidence/coverage: Document environment separation, access boundaries and deployment paths.

Clause	Name	Control Number	Control Title	Control description	In Scope (Y/N)	Justification
		8.32	Change management	Changes to information processing facilities and information systems shall be subject to change management procedures.	No	Screenshot exclusion: No future changes to information processing facilities are expected. Review required: Conflicts with SaaS maintenance, CI/CD releases and Secure Development Policy (SDLC) (peer-reviewed deployments and infrastructure-as-code review). Reassess change management applicability.
		8.33	Test information	Test information shall be appropriately selected, protected and managed.	No	Screenshot exclusion: No testing of information is included in the project. Review required: Conflicts with Secure Development Policy (SDLC) (Testing and QA), which requires test data and prohibits production data in non-production environments. Assess protection of test information.
		8.34	Protection of information systems during audit testing	Audit tests and other assurance activities involving assessment of operational systems shall be planned and agreed between the tester and appropriate management.	Yes	Applicable to protect operational SaaS systems during audits and assurance testing. Policy/document basis: Related documents: ISMS Roles & Responsibilities (audit responsibilities), Access Control Policy (access approval) and ISMS Objectives (audit and penetration testing objectives). Further evidence/coverage: Document test authorisation, scope, access restrictions, timing, safeguards and recovery arrangements; no audit testing procedure was supplied.

Legend

Risk Matrix

	Likelihood 1	Likelihood 2	Likelihood 3	Likelihood 4	Likelihood 5
Impact 5	Low	Low	Low	Low	Medium
Impact 4	Low	Low	Medium	Medium	Medium
Impact 3	Low	Medium	Medium	Medium	High
Impact 2	Low	Medium	Medium	High	High
Impact 1	Medium	Medium	High	High	High

Likelihood

Score	Definition
1 – Rare	May occur only in exceptional circumstances
2 – Unlikely	Not expected to occur under normal conditions
3 – Possible	Might occur at some time
4 – Likely	Will probably occur in most circumstances
5 – Almost Certain	Expected to occur frequently or regularly

Legend

Impact

Score	Definition
1 – Negligible	No significant damage to operations or reputation
2 – Minor	Small disruptions, minor financial or reputational impact
3 – Moderate	Noticeable effect on operations, requires management attention
4 – Major	Serious business disruption, financial loss, or compliance issue
5 – Severe	Critical damage to business, possible legal/regulatory breach

Risk Score

Risk Score	Risk Level	Meaning
1–6	Low	Acceptable risk, monitor
7–14	Medium	Needs mitigation or justification
15–25	High	Unacceptable, treatment required

Legend

Asset Classification: Assets must be classified based on confidentiality, integrity, and availability.

Classification	Description
Confidential	Restricted to authorised personnel only
Restricted	Limited access, operational use
Internal Use Only	General employee access, non-public
Public	Approved for public release